

UNIT - VI

6

Security in IoT

Syllabus

Introduction, Vulnerabilities of IoT, Security Requirements, Challenges for Secure IoT, Threat Modeling. **Key elements of IoT Security** : Identity establishment, Access control, Data and message security, Non-repudiation and availability, Security model for IoT, Challenges in designing IOT applications, Lightweight cryptography.

Contents

6.1	Introduction.....	Dec.-18, 19.....	Marks 6
6.2	IoT Security Issues and Need.....	Dec.-19.....	Marks 6
6.3	Threat Modeling.....	Dec.-19.....	Marks 4
6.4	Key Elements of IoT Security		
6.5	Security Model for IoT		
6.6	Challenges in Designing IoT	May-18, 19	Marks 4
6.7	Lightweight Cryptography		
6.8	Multiple Choice Questions		

6.1 Introduction

➡ SPPU : Dec.-18, 19

- In a network, endpoints are the devices that are connected to the internet, and this includes IoT devices. Every endpoint provides a potential point of entry for a bad actor to expose the network to outside risks. So, as with other endpoints, IoT devices are vulnerable to intense weaponization.
- IoT security covers both physical device security and network security, and impacts the processes, technologies, and measures necessary to protect IoT devices and networks.
- It spans industrial machines, smart energy grids, building automation systems, entertainment devices, and more, including devices that often aren't designed for network security.
- IoT device security must protect systems, networks, and data from a broad spectrum of IoT security attacks, which target various types of vulnerabilities.
- Communication attacks on the data transmitted between IoT devices and servers. Lifecycle attacks on the IoT device as it changes hands from user to maintenance. Attacks on the device software. Physical attacks, which directly target the chip in the device.

Privacy-preserving Sharing of IoT Data

- The increasing development of IoT is dramatically changing the way people share information and communicate with their surrounding environment, enabling a constant, invisible and sometimes unintended data exchange, between things and people.
- The main objective of privacy preservation is ensuring that private data remains protected, while processing or releasing sensitive information.
- Privacy in the Internet of Things is the threefold guarantee to the subject for :
 - a. awareness of privacy risks imposed by smart things and services surrounding the data subject
 - b. individual control over the collection and processing of personal information by the surrounding smart things
 - c. awareness and control of subsequent use and dissemination of personal information by those entities to any entity outside the subject's personal control sphere.
- Fig. 6.1.1 shows an IoT reference model with relevant entities and data flows in a typical IoT application.

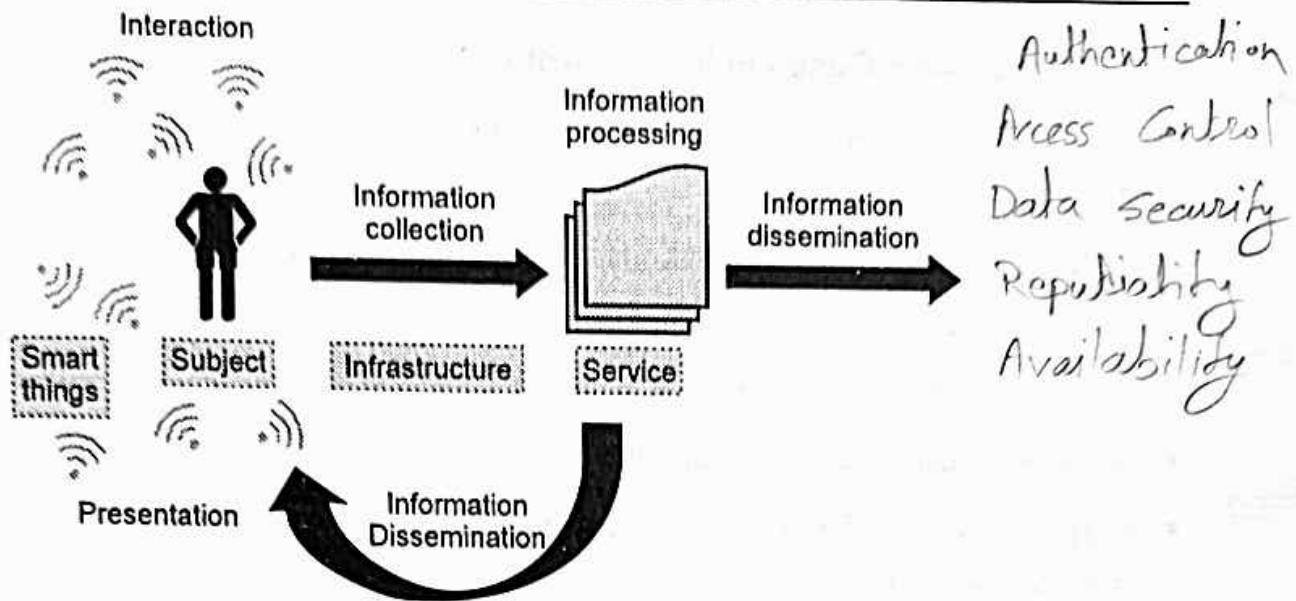


Fig. 6.1.1

- The fundamental privacy mechanisms lie in the intelligent data management so that only the required data is collected. Detecting the redundancy, data is anonymized at the earliest possible stage and then deleted at the earliest convenience.

6.1.1 Vulnerabilities of IoT

- IoT devices are vulnerable largely because these devices lack the necessary built-in security to counter threats. Aside from the technical aspects, users also contribute to the devices' vulnerability to threats. Here are some of the reasons these smart devices remain vulnerable :
 1. Limited computational abilities and hardware limitations.
 2. Heterogeneous transmission technology.
 3. Components of the device are vulnerable.
 4. Users lacking security awareness. Lack of user security awareness could expose smart devices to vulnerabilities and attack openings.
- An IoT device can have one or multiple vulnerabilities that make it an easy target for hackers to gain access to a network and move laterally to more critical devices or systems.
- IoT vulnerabilities due to participation of the number of layers, hardware sublayers and software in applications and services
- The nature of IoT Vulnerabilities varies, for example, sensors, machines, automobiles, wearables, and so on. Each faces different kind of vulnerabilities and has complex security and privacy issues.

6.1.2 Misuse Cases In IoT Security

- Firstly, identify the actors and collaborating actors and develop misuse cases for each of them.
- Purpose : Creation of specifications for communicating the potential risks and rationale.
- Security-relevant decisions to the device platform, application or service.
- Security issues for which misuse cases required in IoT.
- Identity misuse cases : Non-repudiation.
- Crypto offloads : The transfer of cryptographic keys and messages need to be protected from eavesdropper or hackers.
- Eavesdropping
- Fake server
- Fake device platform
- Flooding of TCP/SYN
- Unauthorised access to a data store
- Audit and accountability : Need each transaction to be securely stored to later on auditing and fixing accountabilities.

6.1.3 Attacks

- Various possible attacks in different layers of IoT.
- There are various attack surfaces available for attackers, protection needs to be considered at three different layers :
 - 1) **Edge protection** : Ensures device, mobile app and web app integrity to prevent devices from becoming attack entry points.
 - 2) **Network protection** : Secures communication channels to prevent man-in-the-middle attacks.
 - 3) **Cloud protection** : Assures data privacy and prevents data leakage.

Review Questions

1. List and explain different misuse cases in IoT security ?
2. Explain security model for IoT.

SPPU : Dec.-18, Marks 4**SPPU : Dec.-19, Marks 6**

6.2 IoT Security Issues and Need

**SPPU : Dec.-19**

- The Internet of Things (IoT) refers to a concept of connected objects and devices of all types over the Internet wired or wireless. The popularity of IoT or the Internet of Things has increased rapidly, as these technologies are used for various purposes, including communication, transportation, education, and business development.
 - The unconscious use, not changing passwords and the lack of device updates have increased cybersecurity risks and access to malicious applications to the IoT systems sensitive data.
 - Most of the security professionals consider IoT as the vulnerable point for cyber-attacks due to weak security protocols and policies. Even though several security mechanisms were developed to protect IoT devices from cyber-attacks, security guidelines are not appropriately documented.
 - IoT enabled devices have been used in industrial applications and for multiple business purposes. The apps help these businesses to attain a competitive edge over their competitors.
 - However, due to the excessive adoption of various smart devices with data sharing and integration, the privacy and data breach becomes a significant concern to most businesses, as it interrupts the flow of work, activities, and network services.
 - IoT system functionalities :
 1. Security patch must be upload time to time in microprocessor firmware.
 2. Monitor the access and usage of public network.
 3. User authentication is necessary.
 4. Only after authentication can the controller direct commands for things control that are present in the system.
 - The Internet of Things (IoT) has become a ubiquitous term to describe the tens of billions of devices that have sensing or actuation capabilities and are connected to each other via the Internet.
-  **Risks :**
- The IoT includes everything from wearable fitness bands and smart home appliances to factory control devices, medical devices and even automobiles. Security has not been a high priority for these devices until now.

- The security of the Internet of Things, the following principles can be established.
 - a) **Identity** : Trust is always tied to an identity. Therefore every device needs a unique identity that can't be changed. The device must also be able to prove its identity at all times.
 - b) **Positive intention** : The device and linked service have positive intentions.
 - c) **Predictability and transparency** : The functional scope of the service provided by devices is known to its full extent. There are no undocumented (secret) functions. The behaviour of the system can be checked at any time by independent third parties.
 - d) **Reputation** : An increasing number of positive interactions between the things gradually form a reputation based intelligent network.

6.2.1 Security Architecture

- Fig. 6.2.1 shows IoT security architecture. (See Fig. 6.2.1 on next page.)
- IoT systems are often highly complex, requiring end-to-end security solutions that span cloud and connectivity layers, and support resource-constrained IoT devices that often aren't powerful enough to support traditional security solutions.
- Application layer support user services. This layer helps users access IoT through the interface using PC, mobile equipment etc. This layer also support secure communication protocol and authentication protocols.
- Network layer support wired and wireless communication protocol and technology. This layer is responsible for dependable broadcast of data and information from the below layer.
- Sensors are the monitors that pick up data and relay it for further analysis. Actuators are devices that act as robotic controls. Many IoT attacks have used actuators, such as printers, as launch points into a business's network.
- An IoT security architecture is a blueprint that illustrates all components of the IoT infrastructure for all IoT projects and details how to secure each component.
- In both cases, it is imperative to ensure device access is controlled via settable passwords, encrypt any data stored locally and monitor and contain any executable code run by the device.
- Physical layer gathers all types of information with the help of physical equipment. IoT devices face many threats, including malicious data that can be sent over authenticated connections, exploiting vulnerabilities and/or misconfigurations.

- Such attacks frequently exploit many weaknesses, including but not limited to
 - a) Failure to use code signature verification and secure boot,
 - b) Poorly implemented verification models which can be bypassed.

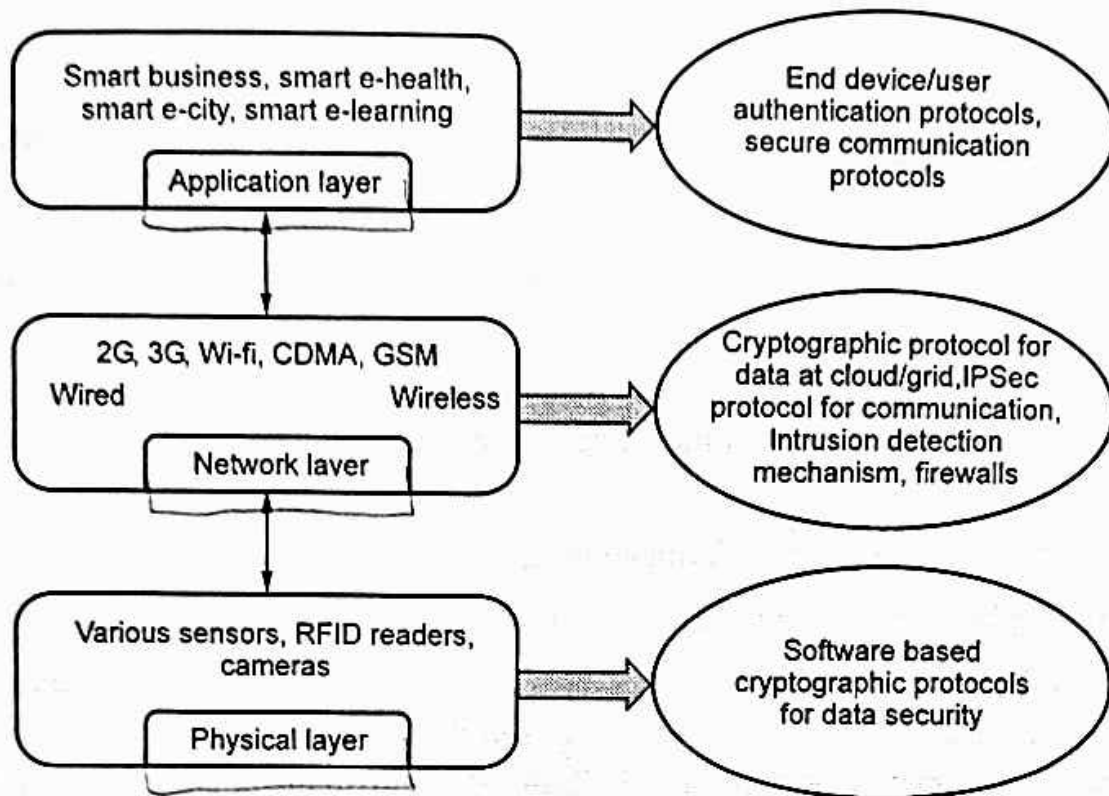


Fig. 6.2.1

- Attackers often use those weaknesses to install backdoors, sniffers, data collection software, file transfer capabilities to extract sensitive information from the system, and sometimes even Command & Control (C & C) infrastructure to manipulate system behaviour.

6.2.2 Security Requirement

- The key requirements for any IoT security solution are :
 1. Device and data security, including authentication of devices and confidentiality and integrity of data.
 2. Implementing and running security operations at IoT scale.
 3. Meeting compliance requirements and requests. *remains active*
 4. Meeting performance requirements as per the use case.
- Application layer: Verification and user's confidentiality
- Support layer: Various encryption algorithms

- Network layer : Distributed denial of service attack
- Physical layer : Authentication.

Review Question

1. List and explain possible vulnerabilities of IOT.

SPPU : Dec.-19, Marks 6

 6.3 Threat Modeling

SPPU : Dec.-19

- Threat modeling is an approach for analyzing the security of an application. It is a structured analysis to identify, quantify, and address the information security risks associated with an application or a system.
- IoT devices face many threats, including malicious data that can be sent over authenticated connections, exploiting vulnerabilities. Such attacks frequently exploit many weaknesses, including but not limited to :
 - (a) failure to use code signature verification and secure boot, and
 - (b) poorly implemented verification models which can be bypassed.
- Attackers often use those weaknesses to install backdoors, sniffers, data collection software, file transfer capabilities to extract sensitive information from the system, and sometimes even command & control (C&C) infrastructure to manipulate system behavior.
- It is well known that IoT devices are generally lagging in terms of network and information security. This is either due to :
 - a) Lax manufacturing standards
 - b) Devices that do not have the computational horsepower or storage space to be secured
- Even if one device is properly secured, unsecured devices can still exist in the organization's ecosystem. This entirely bypasses the scope and reach of IT security teams and opening up entire networks to data breaches. Architecturally-based IoT threat modeling can reveal these IT security bypasses.
- Without specific IoT security, an organization can easily lose control of their IoT ecosystem attack surface. Organizations can, for example, dictate and enforce policies that no personal smart devices are brought into the work environment.
- All that care and monitoring can be thrown out the window if one employee logs into the IT system while working from home. While it is possible to prevent employees from bringing smart devices into the work environment, it would be difficult to manage visitors with IoT devices from entering the building. Securing the IoT ecosystem simply cannot be done by policy mandates.

- Threat modeling is a procedure for optimizing network security by identifying objectives and vulnerabilities, and then defining countermeasures to prevent, or mitigate the effects of, threats to the system.
- Threat modeling is a systematic approach for developing resilient software. It identifies the security objective of the software, threats to it, and vulnerabilities in the application being developed. It will also provide insight into an attacker's perspective by looking into some of the entry and exit points that attackers are looking for in order to exploit the software.

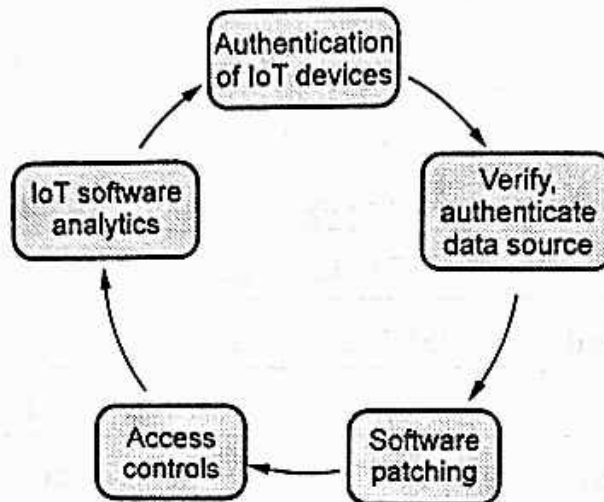
Vulnerability List	Identified Threats
Injection	XML Schema Poisoning
	Accessing/Intercepting/Modifying HTTP Cookies
	HTTP Response Splitting
Broken Authentication and Session Management	JSON Hijacking (aka javaScript Hijacking)
	Read Sensitive Strings Within an Executable
Cross Site Scripting (XSS)	Cross Site Scripting through LOG Files
	Cross Site Scripting in Error Pages
Insecure Direct Object Reference	Privilege Abuse
	Relative Path Traversal
Security Misconfiguration	Padding Oracle Crypto Attack
	Target Programs with Eleavated Privileges
Sensitive Data Exposure	Interception
	Encryption Brute Forcing
Missing Function Level Access Control	Cross Zone Scripting
	Directory Indexing
Cross Site Request Forgery (CSRF)	Cross Site Request Forgery
Using Components with known Vulnerabilities	Using commons-collection for Java Deserialization Vulnerability
Unvalidated Redirects and Forwards	Fake the Source of Data

Review Question

1. Explain Identity Establishment issue with respect to IOT security

SPPU : Dec.-19, Marks 4**6.4 Key Elements of IoT Security**

- Fig. 6.4.1 shows key elements of IoT security.

**Fig. 6.4.1 : Elements of IoT security**

- **Authenticate IoT devices** before they integrate with the centralized network. This step avoids the risk of spoofing attacks on the IoT device which appears as a legitimate device on your network. Attacked devices collect data from other networked devices or transmit malicious data to remaining devices on the network.
- It is essential to authenticate and verify software source running on your IoT device. Unauthenticated software faces the risk of being compromised, and the device cannot detect such tampering issues unless software is supported with a digital signature of the vendor.
- **Software patching** avoids the IoT device from being compromised. However, software updates from authenticated sources must be accepted only. Software patches minimize risks of data loss or interference with business operations. For instance, a device is put for updating; all local data is written on a central network, other devices know when the updating device goes offline, and the update is performed, verified before returning back to the operational mode.
- **Access controls** secure IoT devices as well as the enterprise. Users are assigned roles to perform specific operations. Roles include querying current state of the IoT devices, software updates on these devices, and change device configurations. Other systems present

on the network work on the principle of least privilege that allows users only a minimal set of privileges to perform business functions and technical processes. This method restricts damage caused due to a security breach of user's personal data.

- **IoT software analytics** must be designed on the basis of anomaly detection. Basic guidelines may be pre-defined, and variation from these guidelines should alert the user. For instance, higher-than-expected traffic from some devices would alert users that the devices have been compromised and are in use even after a malicious attack. Considering the response to such anomalous behavior, you can perhaps switch off the affected devices or remove them from the connected network.

❑ Identity Establishment Issue :

- The identity management in IoT is performed by interchanging finding information between the things for first time connection.
- This process is affected to overhear which can lead to man-in-the-middle attack, and thus can threaten the whole IoT structure.
- Hence, there needs to be some pre-defined identity management entity or hub which can observe the relation process of devices by applying cryptography and other techniques to prevent identity theft.
- IoT requires security computes at all three layers; at physical layer for data collection, at network layer for overpower and dispatch, and at application layer to maintain confidentiality, authentication, and integrity.

6.5 Security Model for IoT

- Fig. 6.5.1 shows security model for IoT.

Application Layer	IoT Application
	Application support layer (Middleware technology security)
Transportation Layer	Local Area Network
	Core Network (Internet Security)
	Access Network (Ad hoc security, GPRS security, WiFi security)
Perception Layer	Perception Network (RFID security) (WSN Security)
	Perception Node (RSN Security)

Fig. 6.5.1 : Security model for IoT

- Data and privacy protection is one of the application challenges of IoT. In IoT, RFID systems, WSNs sensors perceive for the end of the information technology, which protect the integrity and confidentiality of information by the password encryption technology.
- There are many ways to encrypt data and information, such as random hash lock protocol (hash function), hash chain protocol, extract key from an infinite channel, Encrypted identifier and so on.
- Identity authentication and access control can determine the communication between both sides and confirm each other's true identity, prevent disguised attacks to ensure the authenticity, validity of the information and so on.
- IoT must ensure the security of all layers. In addition, IoT security should also include the security of whole system crossing the perception layer, transportation layer and application layer.
- Perception layer includes RFID security, WSNs security, RSN security and any others.
- Transportation layer includes access network security, core network security and local network security. There are 3G access network security, Ad-Hoc network security, WiFi security and so on for these sub layers.
- Different network transmission has different technology. Application layer includes application support layer and specific IoT applications. The security in support layer includes middleware technology security, cloud computing platform security and so on.
- IoT applications in different industries have different application requirements. Thus, networking security is a large multi-layered security system, in addition, considering security of each layers also consider cross-layer integration of heterogeneous network security issues.
- Perception layer is mainly about information collection, object perception and object control. Perception layer can be divided into two parts : perception node (sensors or controllers, etc.), perception network that communicates with transportation network.
- Transportation layer mainly provides ubiquitous access environment for perception layer, perception of information transmission and storage, and application layer load other related businesses. Transportation layer can be divided into three layers by function : the access network, the core network and local area. It is a combination of a variety of heterogeneous networks.
- The application support layer, an advanced layer above the transportation layer, supports all sorts of business services and realizes intelligent computation and resources allocation in screening, selecting, producing and processing data. During the whole process, the application support layer can recognize valid data, spam data and even malicious data and filter them in time.

- Application support layer can be organized in different ways according to different services. Usually it includes middleware, M2 M, cloud computing platform and service support platform

6.6 Challenges in Designing IoT

➡ SPPU : May-18, 19

- IoT enables a constant transfer and sharing of data among things and users. In such a sharing environment, authentication, authorization, access control and non-repudiation are important to ensure secure communication.
- The high level of heterogeneity, coupled to the wide scale of IoT systems, is expected to magnify security threats of the current Internet. The high number of inter-connected devices arises scalability issues.
- IoT systems integrate in a seamless way physical objects, data, and computing devices into a global network of information about “smart things”.
- Fig. 6.6.1 shows high level security challenges of IoT.

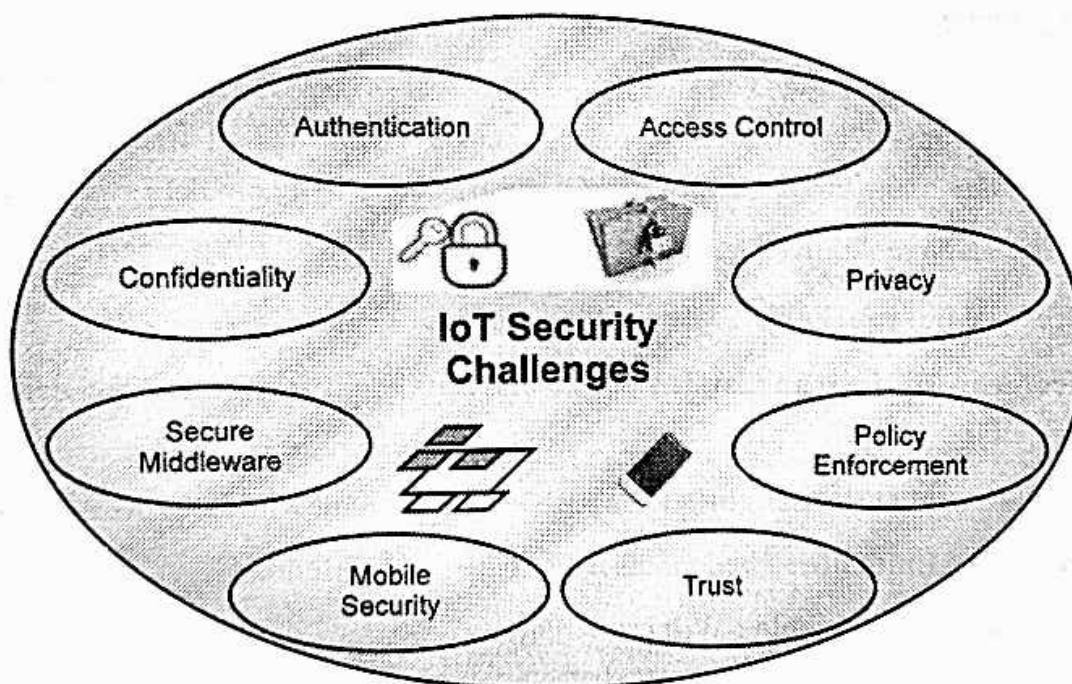


Fig. 6.6.1 : IoT security challenges

- Access control refers to the permissions in the usage of resources, assigned to different actors of a wide IoT network.
- System safety is highly application- or application domain-specific. Trust Model that provides data integrity and confidentiality, and endpoint authentication and non-repudiation between any two system-entities that interact with each other.

- The trust requirements in IoT are related to identify management and access control issues. The IoT-A Privacy Model depends on the following functional components : Identity Management, Authentication, Authorization, and Trust & Reputation.
- Communication security : IoT systems are heterogeneous. Not only because of the variety of the entities involved, but also because they include Devices with various capabilities in terms of communication and processing.
- Communication security model must not only consider the heterogeneity of the system, but it also should guarantee a balance between security features, bandwidth, power supply and processing capabilities.
- IoT devices face many threats, including malicious data that can be sent over authenticated connections, exploiting vulnerabilities. Such attacks frequently exploit many weaknesses, including but not limited to :
 - (a) failure to use code signature verification and secure boot, and
 - (b) poorly implemented verification models which can be bypassed.
- Attackers often use those weaknesses to install backdoors, sniffers, data collection software, file transfer capabilities to extract sensitive information from the system, and sometimes even command & control (C&C) infrastructure to manipulate system behavior.
- The security challenges are as follows :
 - a. **Devices are not reachable** : Most of the time a device is not connected.
 - b. **Devices can be lost and stolen** : Makes security difficult when the device is not connected.
 - c. **Devices are not crypto-engines** : Strong security difficult without processing power.
 - d. **Devices have finite life** : Credentials need to be tied to lifetime.
 - e. **Devices are transportable** : Will cross borders.
- IoT system has a cloud database that is connected to all your devices. These devices are connected to the internet and it could be accessed by the cybercriminals and hackers. As the number of connected devices increases, chances for hackers to breach the security system gets increased.

Review Question

1. What are the challenges for securing IoT ?

SPPU : May-18, 19, Marks 4

6.7 Lightweight Cryptography

- Lightweight cryptography is an encryption method that features a small footprint and/or low computational complexity. It is aimed at expanding the applications of cryptography to constrained devices and its related international standardization and guidelines compilation are currently underway.
- Lightweight cryptography is a cryptographic algorithm or protocol tailored for implementation in constrained environments including RFID tags, sensors, contactless smart cards, health-care devices and so on.
- Design Challenges in Lightweight Cryptography :
 1. **Hardware implementation** : The memory consumption, code size, and energy consumption are the primary metrics, considering that the hardware is earliest.
 2. **Software implementation** : Lightweight cryptography has implemented primitives like the RAM consumption, code size, and the throughput in bytes per cycle, which are essential metrics.
- Lightweight cryptography is an encryption method that features a small footprint and/or low computational complexity.
- Applying encryption to sensor devices means the implementation of data protection for confidentiality and integrity, which can be an effective countermeasure against the threats. Lightweight cryptography has the function of enabling the application of secure encryption, even for devices with limited resources.
- The following factors on the implementation are required for lightweight cryptography.
 1. Size (circuit size, ROM/RAM sizes)
 2. Power
 3. Power consumption
 4. Processing speed (throughput, delay)

Symmetric Key and Public Key Cryptographies

- Cryptography can roughly be divided into symmetric key and public key (asymmetric key) cryptographies.
- The contents of the key may consist of public/private key pairs, secret keys, non-secret parameters, initialization parameters, and supporting key management in various instances, depending on the nature of the scheme being used.

- Symmetric key cryptography also known as shared key ciphers. It is type of cryptography in which the same key is used by both the sender and receiver for the encryption and decryption of plaintext and ciphertext, respectively.
- Asymmetric key cryptography uses two types in a pair called as public key and private key in a pair. It is also called as public key cryptography. The private key is used to decrypt the cipher text and generate the digital signature, whereas the public key is used to encrypt plaintext and to verify the digital signature.